

1. ¿Crees necesario que tu empresa se certifique del ENS? Justifica la respuesta.

Sí, y en el caso de Ecocycle la necesidad es doble.

En primer lugar, aunque el Real Decreto 311/2022 solo obliga al sector público y a sus proveedores directos, Ecocycle tiene una característica clave: trabaja con residuos electrónicos de otras empresas y potencialmente con Administraciones Públicas (ayuntamientos, organismos medioambientales). En el momento en que Ecocycle preste servicios o actúe como proveedor de cualquier entidad pública, **el cumplimiento del ENS pasa a ser obligatorio**, no opcional.

En segundo lugar, incluso si Ecocycle opera únicamente en el sector privado en su fase inicial, certificarse en el ENS tendría un valor estratégico enorme:

- **Credibilidad ante clientes empresariales:** Las empresas que le ceden sus residuos electrónicos confían datos de sus procesos internos a Ecocycle. Contar con una certificación de seguridad reconocida es un argumento comercial diferenciador.
- **Base para cumplir el RGPD:** El ENS proporciona un marco de control que facilita directamente el cumplimiento del Reglamento General de Protección de Datos, al que Ecocycle sí está obligada.
- **Escalabilidad:** Ecocycle está en fase inicial (S.L. con pocos socios, infraestructura en AWS Free Tier), pero si crece y entra en licitaciones públicas o contratos con grandes empresas, ya contará con la certificación exigida.

En conclusión, aunque hoy no sea obligatorio para Ecocycle, certificarse en el ENS es una inversión que protege el negocio, genera confianza y evita tener que correr contra el tiempo cuando llegue a ser exigible.

2. ¿Qué medidas tomarías para que los empleados conocieran y cumplieran las políticas?

El principal riesgo en una empresa como Ecocycle no es técnico, sino humano. Al ser una S.L. en fase inicial con pocos colaboradores, el reto es hacer que la seguridad sea algo natural y no una burocracia percibida como innecesaria. Tomaría las siguientes medidas:

Formación desde el primer día (onboarding de seguridad): Cualquier nuevo socio o colaborador firmaría desde el inicio un Compromiso de Confidencialidad y recibiría una formación básica en las políticas de uso de los sistemas (AWS, dispositivos personales,

contraseñas). Esto está directamente recogido en la Política de Seguridad de la Información de Ecocycle ya aprobada.

Comunicación accesible: Las políticas estarán redactadas en lenguaje sencillo y sin tecnicismos, disponibles en un espacio compartido (p. ej. un repositorio en AWS S3 o una carpeta compartida). No sirve de nada una política que nadie lee porque no entiende.

Simulacros de phishing y recordatorios periódicos: Dada la pequeña escala de Ecocycle, bastaría con simulaciones sencillas y boletines internos periódicos con recordatorios prácticos (cómo gestionar contraseñas, qué hacer ante un correo sospechoso, etc.).

Responsabilidad asignada: La Política de Seguridad de Ecocycle ya establece que un socio asume el rol de Responsable de Seguridad. Esta persona es el punto de referencia para dudas y también quien verifica que las normas se cumplen.

Consecuencias claras: Las políticas deben indicar explícitamente qué ocurre si se incumplen. Sin consecuencias definidas, las normas pierden autoridad, especialmente en equipos pequeños donde puede haber relajación por exceso de confianza entre compañeros.

3. ¿Qué es un SGSI? ¿Por qué es necesario implantarlo?

Un **SGSI (Sistema de Gestión de Seguridad de la Información)** es el conjunto estructurado de políticas, procedimientos, controles y recursos que una organización aplica de forma sistemática para proteger su información. El estándar de referencia internacional es la norma **ISO/IEC 27001**, que ya está contemplada en la Política de Seguridad de Ecocycle.

Lo que distingue a un SGSI de simplemente "tener medidas de seguridad" es que funciona bajo el ciclo **PDCA (Planificar – Hacer – Verificar – Actuar)**, lo que convierte la seguridad en un proceso continuo y no en un proyecto puntual.

¿Por qué es necesario implantarlo en Ecocycle?

Ecocycle gestiona datos personales de clientes y proveedores, opera en la nube (AWS), y maneja información relacionada con residuos electrónicos de otras empresas. Sin un SGSI, la seguridad dependería de decisiones improvisadas y reacciones ante incidentes ya ocurridos. Con un SGSI, aunque sea adaptado al tamaño inicial de la empresa:

- Se identifican qué activos son críticos (cuentas AWS, datos de clientes, documentación interna) y qué riesgos los amenazan.
- Se establecen controles proporcionales a esos riesgos, evitando gastar recursos donde no hace falta y cubriendo donde sí.

- Se demuestra ante clientes, proveedores y autoridades (como la AEPD) que Ecocycle trata la información con rigor.
- Se facilita el cumplimiento del RGPD y, en el futuro, de la Directiva NIS 2, a la que Ecocycle podría estar sujeta si crece y opera en el sector de gestión de residuos a mayor escala.

En definitiva, implantar un SGSI en Ecocycle, aunque sea en versión básica adaptada a una pyme, es lo que transforma la seguridad de una intención en una práctica real y demostrable.